

Seminar Preparation

Quantitative Risk Modelling

Review the paper by Aijaz, M. and Nazir, M. (2024) Modelling and analysis of social engineering threats using the attack tree and the Markov model. International Journal of Information Technology, 16(2), pp.1231-1238. then prepare answers to the following questions:

a. Main challenges in modelling SETs, and how the study addresses them

Social engineering exploits human vulnerability rather than technical flaws, so it bypasses conventional controls and resists formal modelling (Aijaz and Nazir, 2024). The core difficulty is that human behaviour is hard to quantify, and the field has historically lacked rigorous methods for evaluating SET outcomes. The study addresses this by decomposing each attack into two measurable components, the communication modality and the persuasion principle, then assigning probabilities drawn from published frequency and effectiveness data. This converts a soft, behavioural problem into a structured probabilistic one. The acknowledged weakness is data quality: the authors concede the underlying statistical evidence is insufficient to rely on, which is the classic limitation of any quantitative method built on uncertain inputs.

b. How persuasion principles and modalities drive success, and why systematic analysis matters

Modality is the channel (email, voice call, face-to-face); the persuasion principle is the psychological lever (authority, reciprocity, commitment, and so on, drawing on Cialdini's influence principles). Their combination determines both how often an attack is attempted and how likely it is to succeed. The study finds a useful asymmetry: single-principle attacks occur more frequently but succeed less often, whereas combining principles lowers occurrence yet raises success probability (Aijaz and Nazir, 2024). Systematic analysis matters because it lets defenders rank threats by evidence rather than intuition, and target awareness training at the specific levers most likely to work against their workforce, rather than treating all social engineering as a single undifferentiated risk.

c. Role of the Attack Tree and Markov Chain models in estimating AOP and ASP

The two models answer different questions. The attack tree (Schneier, 1999) computes Attack Occurrence Probability: the root is the attacker goal, leaves are modalities and persuasion principles, joined by AND and OR gates, with probabilities propagated bottom-up (OR takes the maximum, AND multiplies). It models how likely an attack is to be mounted. The Markov chain models how likely it is to succeed: attacker progress is represented as four states (Disconnect, Connect, Persuade, Success), with transition probabilities derived from modality and principle effectiveness. Attack Success Probability is the stationary distribution of the Success state, computed via Monte Carlo simulation (Aijaz and Nazir, 2024). Together they separate likelihood of attempt from likelihood of success, which conventional approaches tend to conflate.

d. How the findings support policy frameworks for mitigation

Quantified AOP and ASP values let organisations prioritise defences by risk rather than by ease of implementation. Because the model isolates which principle-modality combinations are most dangerous, training and awareness programmes can be focused where they yield the greatest reduction in success probability, improving return on a limited security budget. The ranking output also supports defensible, auditable decisions about residual risk acceptance. The caveat for policy use is that the model omits attacker capability, required resources, and victim profile (demographics, workload, culture), so its outputs should inform policy, not dictate it.

Note:

A point worth raising in discussion: the model's reliance on assumed frequency and effectiveness figures means its precision exceeds its accuracy. The numbers look authoritative, but if the input probabilities are guessed, the output is quantitative theatre rather than quantitative rigour. How much should a policymaker trust a precise ASP figure built on uncertain data?

Explanation

By "ASP figure" I mean the Attack Success Probability percentages reported in the paper's results table (Table 3), for example case scenario 9 at 18% or case scenario 1 at 12%.

My point was about trusting those specific numbers. They are presented to a decimal-level precision, which makes them look authoritative. But they are the output of a calculation whose inputs are the effectiveness probabilities in Tables 1 and 2, and the authors themselves describe those inputs as "assumed" frequency and effectiveness values, conceding the underlying evidence is insufficient to rely on.

So the precision is misleading. A figure like 18% implies a level of measurement accuracy that the guessed inputs cannot support. The calculation is internally valid; the question is whether the numbers feeding it are accurate enough to base real decisions on. That is the trap with quantitative risk methods generally: a precise-looking output can disguise weak data underneath, which is what I meant by "quantitative theatre."

Post Seminar blog article sharing

Extract of the email sent to the tutor on May 27, 2026, at 7:59pm UAE time.

“As mentioned, here is the public blog article regarding the Social Engineering campaign that our Security team disrupted. The campaign specifically targeted tech teams in the crypto space:

- **Contagious Interview: Fireblocks Disrupts Recruiting Scam**
<https://www.fireblocks.com/blog/contagious-interview-recruiting-scam>

Also, since you mentioned the topic of digital assets such as Bitcoin and stablecoins, I thought you might be interested in this whitepaper focusing on securing digital assets in an evolving threat landscape. It was written by our security team here at Fireblocks:

- **Securing Digital Assets in an Evolving Threat Landscape: The Fireblocks Defense-in-Depth Approach to Security** <https://www.fireblocks.com/report/the-fireblocks-defense-in-depth-approach-to-security>

I hope you find these resources useful. Please feel free to share them with the broader team; since this is public domain information, you are welcome to distribute it freely.”